

Marco integrativo GQM + PRAGMATIC para indicadores FAIR a nivel nacional

1. Propósito del marco

Este marco integra la metodología GQM (Goal–Question–Metric) con los criterios PRAGMATIC para evaluar y gobernar un conjunto de indicadores FAIR aplicados al nivel nacional y sectorial. El objetivo es garantizar que cada métrica de ciber-riesgo:

- Nace de un objetivo estratégico explícito (Goal).
- Se contextualiza mediante preguntas claras (Question).
- Se implementa como métrica concreta, trazable y evaluada (Metric).
- Se revisa sistemáticamente frente a los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.

2. Resumen de indicadores FAIR de referencia

Trabajaremos con un conjunto base de indicadores derivados del marco FAIR aplicado a un país como España:

1. IFEP-S: Índice de Frecuencia de Eventos de Pérdida Cibernética por Sector.
2. INAT: Índice Nacional de Actividad de Amenazas.
3. ISUS-C: Índice de Susceptibilidad de Controles (madurez de controles por sector).
4. PAE-S: Pérdida Anual Esperada por Sector (en euros y en % del PIB sectorial).
5. PaExt-S: Percentiles de Pérdida Extrema (por ejemplo, 95 % y 99 % por sector crítico).
6. IMat-N: Indicador de Materialidad Nacional (proporción de escenarios con impacto financiero “material”).
7. IEReg-N: Índice de Exposición Regulatoria Nacional (pérdida esperada por sanciones y obligaciones regulatorias).
8. IECtrl-S: Índice de Eficacia de Controles (derivado de FAIR-CAM) por sector.
9. IAut-N: Índice de Automatización e IA en la cuantificación FAIR a nivel nacional/sectorial.
10. IPart-N: Índice de Participación Sectorial/Nacional en esquemas de datos FAIR de riesgo.

Cada uno de estos indicadores se despliega en estructuras GQM y se evalúa con PRAGMATIC.

3. Plantilla GQM genérica

A efectos de consistencia, usaremos la siguiente plantilla para cada indicador:

- Goal (G): objetivo nacional o sectorial al que contribuye el indicador.
- Question (Q): una o varias preguntas que, al responderse, permiten evaluar el grado de avance hacia el objetivo.
- Metric (M): definición operativa de la métrica, con unidad, fuentes de datos y periodicidad.

4. Ejemplo 1 – IFEP-S (Índice de Frecuencia de Eventos de Pérdida por Sector)

G – Objetivo

Reducir de forma sostenible la frecuencia de eventos de pérdida cibernética significativos en los sectores críticos del país, alineando inversiones y políticas públicas con los patrones reales de ocurrencia.

Q – Preguntas

- Q1: ¿Con qué frecuencia se producen, por sector, incidentes de seguridad que generan pérdida económica significativa?
- Q2: ¿Cómo evoluciona esa frecuencia en el tiempo y frente a objetivos nacionales de reducción del riesgo?

M – Métrica

- M1: IFEP-S = número anual de eventos de pérdida cibernética significativos por sector, normalizado por 100 organizaciones o por volumen de actividad (por ejemplo, ingresos agregados del sector).
- Unidad: eventos/año/(100 organizaciones) o eventos/año/1000 M€ de ingresos sectoriales.
- Fuente: notificaciones de CSIRTs sectoriales, reguladores, aseguradoras y encuestas FAIR armonizadas.
- Periodicidad: anual, con actualización parcial trimestral cuando existan datos.

5. Ejemplo 2 – PAE-S (Pérdida Anual Esperada por Sector)

G – Objetivo

Cuantificar la exposición económica agregada por ciber-riesgo de cada sector crítico, para orientar prioridades de inversión pública y privada, así como políticas de aseguramiento y resiliencia.

Q – Preguntas

- Q1: ¿Cuál es la pérdida económica anual esperada por ciber-riesgo en cada sector crítico?
- Q2: ¿Qué proporción representa sobre el PIB sectorial y sobre el PIB nacional?
- Q3: ¿Cómo varía la pérdida esperada en los distintos escenarios de inversión en controles?

M – Métrica

- M1: PAE-S = valor medio de la distribución de pérdida anual agregada por sector (suma de ALE de las organizaciones, ajustada por tamaño y cobertura).
- M2: $PAE-S_ \%PIB = PAE-S / PIB \text{ sectorial}$.
- Unidad: euros/año; porcentaje sobre PIB sectorial.
- Fuente: modelos FAIR organizativos, agregados mediante encuestas y datos de mercado; cuentas nacionales.
- Periodicidad: anual.

6. Ejemplo 3 – IEReg-N (Índice de Exposición Regulatoria Nacional)

G – Objetivo

Evaluar el impacto potencial de obligaciones regulatorias (GDPR, NIS2, ENS, sectoriales) sobre la pérdida económica nacional por ciber-riesgo, para mejorar la coherencia entre regulación, capacidad de cumplimiento y resiliencia.

Q - Preguntas

- Q1: ¿Qué parte de la pérdida económica esperada se debe a sanciones, litigios y costes de cumplimiento regulatorio derivados de incidentes?
- Q2: ¿Cómo varía ese porcentaje entre sectores y en el tiempo?

M - Métrica

- M1: $IReg-N = (\text{pérdida anual esperada por sanciones, litigios y costes regulatorios}) / (\text{pérdida anual esperada total por ciber-riesgo})$, a nivel país.
- Unidad: proporción (0–1) o porcentaje (%).
- Fuente: descomposición FAIR de pérdidas secundarias en organizaciones; datos de reguladores y tribunales.
- Periodicidad: anual.

7. Esquema QM resumido para el resto de indicadores

INAT (Índice Nacional de Actividad de Amenazas)

- G: Monitorizar y anticipar tendencias de actividad de actores de amenaza relevantes para el país, para ajustar posturas defensivas y niveles de alerta.
- Q: ¿Cómo evoluciona el volumen y la sofisticación de intentos de ataque dirigidos contra sectores nacionales clave?
- M: Índice compuesto que incluye número de campañas relevantes, nuevas técnicas observadas (mapeadas a ATT&CK) y volumen de eventos de amenaza, normalizados por superficie de ataque.

ISUS-C (Índice de Susceptibilidad de Controles)

- G: Reducir la probabilidad de compromiso exitoso mejorando la fuerza de control relativa a la capacidad de los atacantes.
- Q: ¿Cuál es la brecha entre la capacidad esperada del atacante y la fuerza real de nuestros controles por sector?
- M: Puntuación normalizada (0–1) derivada de la estimación FAIR de vulnerabilidad (probabilidad de que un evento de amenaza se convierta en pérdida).

PaExt-S (Percentiles de Pérdida Extrema)

- G: Conocer el impacto potencial de escenarios catastróficos de ciber-riesgo por sector, para alimentar pruebas de estrés y planificación de contingencias.
- Q: ¿Cuál sería la pérdida en escenarios de cola (95 %, 99 %) y cómo se compara con la capacidad de absorción del sector?
- M: Pérdida agregada a percentiles altos de la distribución de pérdidas anuales (o por incidente) por sector.

IMat-N (Indicador de Materialidad Nacional)

- G: Identificar la proporción de escenarios de ciber-riesgo que alcanzan umbrales de materialidad financiera relevante para supervisores y mercados.
- Q: ¿Qué porcentaje de los escenarios FAIR modelados en el país se consideran “materiales” según criterios financieros acordados?
- M: Número de escenarios materiales / número total de escenarios evaluados a nivel nacional.

IECtrl-S (Índice de Eficacia de Controles)

- G: Maximizar el impacto de las inversiones en controles de seguridad en la reducción de pérdida esperada.
- Q: ¿Qué reducción de ALE se atribuye a los controles existentes y planeados por sector?
- M: Proporción de reducción de ALE derivada de la implementación de controles, según modelos FAIR-CAM u otros equivalentes.

IAut-N (Índice de Automatización e IA en cuantificación FAIR)

- G: Aumentar la eficiencia, consistencia y capacidad de actualización de la cuantificación de riesgo a nivel nacional.
- Q: ¿Hasta qué punto los procesos FAIR se apoyan en automatización, simulaciones y modelos de IA?
- M: Escala de madurez (por ejemplo, 0–5) basada en criterios de automatización de datos, uso de Monte Carlo y uso de IA en parámetros FAIR.

IPart-N (Índice de Participación Sectorial/Nacional)

- G: Fomentar un ecosistema colaborativo de datos de ciber-riesgo, que permita indicadores agregados y aprendizaje colectivo.
- Q: ¿Qué proporción de organizaciones relevantes contribuye activamente con datos a iniciativas FAIR nacionales o sectoriales?
- M: Número de organizaciones participantes / número total de organizaciones objetivo, por sector y a nivel país.

8. Integración GQM a nivel de sistema nacional

Para lograr trazabilidad de arriba abajo, se recomienda documentar explícitamente:

- Los objetivos nacionales de resiliencia digital (por ejemplo, reducción de PAE-N en un X % en cinco años).
- Las preguntas de política pública a las que se quiere responder (por ejemplo, “¿qué sectores necesitan más apoyo regulatorio o financiero?”).
- El conjunto de métricas FAIR seleccionadas, su definición técnica y sus evaluaciones PRAGMATIC asociadas.

De este modo, el ciclo GQM actúa como columna vertebral: los objetivos fijan el rumbo, las preguntas orientan la interpretación, y las métricas FAIR —evaluadas con PRAGMATIC— aseguran que los datos técnicos no se convierten en un fin en sí mismos, sino en instrumentos de decisión.